PRACTICAL LABORATORY ASSIGNMENT

Full Name	OSAWARU PRAISE
Registration Number	C11/26/CGRCE/17564
Date Submitted	13th November 2026
Course	GRC 103 Week 4 Lab

Task 1 Assess and prioritise the risks

Risk Register

ID	Risk	Asset	Threat	Weakness	Business impact	Owner
R1	Service disruption	Booking and clinical systems across three clinics	Ransomware encrypting systems	Recovery untested; no proven way to restore	Appointments cancelled, delayed care, paper fallback only	Operations Director
R2	Sensitive-data loss	Patient records	Data copied out before or during encryption	Same entry paths as R1; no early detection	Privacy breach, regulatory exposure, loss of patient trust	Data Protection Officer
R3	Unnecessary supplier exposure	Unused supplier workflow	Attacker or compromised supplier using a pathway with no business need	Workflow enabled but unused	Avoidable entry point into the environment	IT Manager (with Procurement)
R4	Delayed detection	Staff mailboxes and security alerts	Phishing email and follow-on intrusion going unnoticed	Phishing reports have no escalation owner	Attacker dwell time grows, so R1 and R2 get worse	Head of IT Security

HSE facts (official source):

- A phishing email reached an HSE network user in March 2021, and opening the attachment secretly downloaded malware.
- The ransomware attack was triggered in May 2021. So there was roughly a two-month window between the initial compromise and the visible impact.

Scoring (likelihood × impact, 1–5)

ID	L	I	Score	Rating	Why
R1	4	5	20	Critical	Ransomware is common in health, and untested recovery means we can't count on restoring. Impact is maximum because essential bookings must continue.
R2	3	5	15	High	Likelihood is moderate because theft needs a successful intrusion first. Impact is maximum because health data is highly sensitive and exposure can't be undone.
R3	4	3	12	High	Likelihood is high because an enabled, unused pathway is an open door that gives nothing back. Impact is moderate because it's an entry point, not the loss event itself.
R4	4	4	16	High	Likelihood is high because there's no one to act on a report. Impact is significant because delay magnifies R1 and R2, as the March-to-May gap at HSE shows.

Task 2 Choose and justify a treatment portfolio

Option	Cost	Strategy	Risks addressed
A Retire unused supplier workflow	$5,000	Avoidance (removes the exposure entirely)	R3
C Protected backups, restoration tests, recovery plan	$30,000	Mitigation	R1 (also limits the damage from R2)
D Managed detection and escalation	$35,000	Mitigation	R4, plus earlier containment of R1 and R2
E Targeted training and reporting process	$10,000	Mitigation	R4 (gives phishing reports an owner)
Total	**$80,000**		**Remaining: $20,000**

Task 3 Calculate retained financial exposure

Insurance calculations (option G)

Formula: insurer payment = min(max(loss − $25,000, 0), $250,000)

	Covered loss $180,000	**Covered loss $400,000**
Loss minus deductible	$155,000	$375,000
Insurer payment	$155,000	$250,000 (capped)
Retained loss	$180,000 − $155,000 = $25,000	$400,000 − $250,000 = $150,000
Premium	$20,000	$20,000
Total first-year outlay	$45,000	$170,000

Task 4 Respond to a change

Initial decision (recorded before the change)

A + C + D + E = $80,000. Reserve $20,000. Deferred: B, F and G.

What changed

1. The restoration test failed, so C is no longer a control we can rely on. R1 (Critical, 20) can't drop until a retest passes.
2. Paper bookings last only four hours. After that, essential bookings stop unless there's a continuity plan beyond paper.
3. B rises from $25,000 to $35,000. It was already deferred, and at the new price it can't fit alongside D (115k).

Revised portfolio

Option	Cost	Change
A Retire supplier workflow	$5,000	Kept
C Backups, tests, recovery plan	$30,000	Kept and made the first priority**.** Scope now includes fixing the failure and retesting.
D Managed detection and escalation	$35,000	Kept
E Training and reporting process	$10,000	Kept
Committed	$80,000	
Reserve	$20,000	Earmarked for recovery remediation and retest (my assumption, since the brief gives no price for this)

Who owns what remains

Risk	Status	Owner
R1 Service disruption	Critical, not accepted. Stays open until a retest passes.	Operations Director
R2 Data loss	High	Data Protection Officer
R3 Supplier exposure	Treated by A	IT Manager
R4 Delayed detection	High, treated by D and E	Head of IT Security
Credential compromise (B deferred)	New time-limited acceptance	IT Manager

Task 5 Plan and communicate the response

#	Action	Owner	Cost	Target date	Effectiveness test
1	Disable and decommission the unused supplier workflow (A)	IT Manager	$5,000	20 Nov	Workflow shown as removed, supplier access revoked, and a trigger attempt fails. Sign-off recorded.
2	Name the phishing-report escalation owner and process (E)	Head of IT Security	within E ($10,000)	20 Nov	A simulated phishing report is acknowledged by the owner within the agreed time.
3	Deliver targeted awareness training (E)	Head of IT Security	within E	4 Dec	A simulated phishing exercise shows staff reporting rather than opening the attachment.
4	Protect backups and write the recovery plan (C)	Operations Director	within C ($30,000)	27 Nov	Backups are shown to be protected from alteration, and the plan names the booking systems and recovery order.
5	Onboard managed detection and escalation (D)	Head of IT Security	$35,000	4 Dec	A simulated alert reaches the named owner and triggers escalation.

6	Fix the restoration failure and retest (C plus reserve)	Operations Director	up to $20,000 reserve	11 Dec	Essential bookings are restored within four hours, matching the paper limit. This is the pass or fail test for R1.
7	Board review of results and acceptances	Board Risk Committee (simulated)	$0	16 Dec	Decision recorded on acceptances and any reserve release.

B. Proposed residual risks

ID	Initial	Proposed residual	Assumptions
R1 Service disruption	4×5 = 20 Critical	3×5 = 15 High	Only if the retest passes. Until then, R1 stays at 20 Critical, because a failed or untested control isn't proven.
R2 Data loss	3×5 = 15 High	2×5 = 10 High	D shortens detection time. Impact stays 5 because health data can't be un-exposed, and nothing here prevents theft directly.
R3 Supplier exposure	4×3 = 12 High	1×3 = 3 Low	The workflow is verified as gone. Avoidance is the most reliable strategy here.
R4 Delayed detection	4×4 = 16 High	2×4 = 8 Medium	D is live and the escalation owner is named. Likelihood only drops if the simulated alert and report tests succeed.

C. Proposed acceptances

Item	Owner	Expiry	Review triggers	Simulated approver
Credential-compromise exposure (B deferred at $35,000)	IT Manager	31 May 2027	Phishing incident, credential-abuse alert, or retest outcome changing the budget	Board Risk Committee
Lateral-movement exposure (F deferred)	IT Manager	31 May 2027	Detection alert showing movement between systems	Board Risk Committe

D. Board memo (about 270 words, so please recount in Word)

To: Board Risk Committee

From: Praise Osawaru

Date: 13 November 2026

Subject: Ransomware risk treatment, decision requested

Decision requested
Approve a first-year treatment budget of $80,000, with a further $20,000 held in reserve, released only if the restoration retest fails again. Approve two time-limited risk acceptances, below.

Why now
Our recovery has never worked in testing, and a restoration test has failed. Paper bookings can sustain clinics for only four hours. At HSE, a phishing attachment opened in March preceded the May ransomware trigger, showing how slow detection compounds damage.

Budget
Supplier workflow retirement $5,000; protected backups, recovery plan and retesting $30,000; managed detection and escalation $35,000; targeted training and reporting $10,000. Remaining: $20,000.

Service-continuity priorities

1. Restore essential bookings within four hours, proven by a passed retest by 11 December.
2. Name an owner for phishing reports and alerts by 20 November.
3. Close the unused supplier pathway by 20 November.

Unresolved risks
Service disruption stays Critical until a retest passes. It cannot be accepted. Sensitive-data loss remains High after treatment. MFA (now $35,000) and network segmentation are deferred. We ask the Board to accept that exposure until 31 May 2027, owned by the IT Manager, with early review after any phishing incident, credential-abuse alert or failed retest.

Insurance was assessed but deferred. It pays after a loss and does not keep clinics running. Accountability for patient data remains ours.